# ADOPCIÓN DE ESTRATEGIAS DE CIBERSEGURIDAD PARA LA PROTECCIÓN DE LA INFORMACIÓN

La cadena de suministro de software incluye el código propio, las librerías de terceros, el repositorio de código, el pipeline de integración/despliegue continuo (CI/CD) y la infraestructura donde finalmente corre la aplicación. Cuando una librería de terceros falla, es maliciosa o resulta incompatible, y el proceso de despliegue no cuenta con controles de verificación, el resultado es el colapso de la aplicación al llegar al usuario final: el servicio no inicia, queda caído o expone datos. A continuación se presenta la tabla de vulnerabilidades y la tabla de riesgo asociadas específicamente a este escenario, aplicando la metodología Probabilidad × Impacto vista en la formación (escala 1 a 5; 1-4 Bajo, 5-9 Medio, 10-15 Alto, 16-25 Crítico).

## 1. Tabla de Vulnerabilidades

| ID | Activo afectado | Vulnerabilidad identificada | Amenaza asociada | Prob. (1-5) | Impacto (1-5) | Nivel (P×I) | Control / Mitigación propuesta |
|---|---|---|---|---|---|---|---|
| **V-01** | Librería de terceros (dependencia externa) | Dependencias sin versión fija ni archivo de bloqueo (lockfile) | Actualización automática incompatible o maliciosa | 4 | 5 | **20 - CRÍTICO** | Fijar versiones exactas + lockfile + Dependabot |
| **V-02** | Pipeline CI/CD (build y despliegue) | Ausencia de análisis de composición de software (SCA/SAST) antes de publicar | Paso de librería vulnerable directo a producción | 5 | 4 | **20 - CRÍTICO** | Integrar escaneo SCA/SAST (Snyk, Trivy) como paso obligatorio |
| **V-03** | Infraestructura de despliegue (contenedores/nube) | No existe ambiente de staging previo a producción | El fallo de la librería solo se detecta cuando ya llegó al usuario final | 4 | 4 | **16 - CRÍTICO** | Flujo dev → staging → prod con puntos de control |
| **V-04** | Aplicación desplegada (frontend/backend) | No hay estrategia de reversión (rollback) automática | Indisponibilidad prolongada del servicio tras un despliegue fallido | 4 | 4 | **16 - CRÍTICO** | Estrategia Blue/Green con rollback automático |
| **V-05** | Registro de paquetes (npm / PyPI / Nexus) | Registro sin protección frente a dependency confusion / typosquatting | Instalación de un paquete público malicioso con nombre similar al interno | 3 | 5 | **15 - ALTO** | Registro privado con lista blanca (allowlist) de paquetes |

| ID | Activo afectado | Vulnerabilidad identificada | Amenaza asociada | Prob. (1-5) | Impacto (1-5) | Nivel (P×I) | Control / Mitigación propuesta |
|---|---|---|---|---|---|---|---|
| **V-06** | Artefactos de compilación (build) | Artefactos generados sin firma digital | Suplantación o inyección de código durante el proceso de build | 3 | 4 | **12 - ALTO** | Firmar artefactos (Cosign/Sigstore) y verificar antes de desplegar |
| **V-07** | Documentación técnica del despliegue | No existe SBOM (inventario de componentes de software) | Respuesta lenta ante el incidente por desconocer qué librería falló | 4 | 3 | **12 - ALTO** | Generar SBOM (formato CycloneDX) en cada compilación |
| **V-08** | Infraestructura de producción | Falta de monitoreo y verificaciones de salud (health-checks) post-despliegue | Detección tardía del colapso del servicio | 5 | 3 | **15 - ALTO** | Monitoreo con alertas automáticas (Prometheus/Grafana) |

## 2. Tabla de Riesgo

| ID | Vulnerabilidad de origen | Riesgo (qué puede ocurrir) | Consecuencia para el usuario final | Prob. | Imp. | P×I | Nivel | Control / Plan de mitigación | Responsable |
|---|---|---|---|---|---|---|---|---|---|
| **R-01** | V-01 | Colapso total del despliegue por librería incompatible | La aplicación queda fuera de servicio para todos los usuarios. | 4 | 5 | 20 | **CRÍTICO** | Pinning de versiones + staging + rollback automático | DevOps |
| **R-02** | V-02 | Explotación de una vulnerabilidad (CVE) conocida en producción | El atacante roba datos o ejecuta código a costa del usuario final. | 4 | 5 | 20 | **CRÍTICO** | SCA obligatorio en el pipeline + parcheo prioritario | Seguridad |
| **R-03** | V-03, V-04 | Despliegue directo a producción sin red de seguridad | El usuario recibe una aplicación caída o con errores (5xx). | 4 | 4 | 16 | **CRÍTICO** | Gates de calidad en staging + Blue/Green + rollback | DevOps |
| **R-04** | V-05 | Instalación de un paquete de terceros malicioso (typosquatting) | Se entrega al usuario una app con backdoor que compromete sus datos. | 3 | 5 | 15 | **ALTO** | Registro privado con allowlist + firma de paquetes | DevOps |

| ID | Vulnerabilidad de origen | Riesgo (qué puede ocurrir) | Consecuencia para el usuario final | Prob. | Imp. | P× I | Nivel | Control / Plan de mitigación | Responsable |
|---|---|---|---|---|---|---|---|---|---|
| **R-05** | V-08 | Detección tardía del colapso por falta de monitoreo | La falla se prolonga porque el equipo se entera por reclamos de usuarios. | 5 | 3 | 15 | **ALTO** | Observabilidad, alertas y guardias (on-call) | SRE |
| **R-06** | V-06 | Despliegue de un artefacto de build manipulado | El usuario final ejecuta una versión distinta a la auditada, de comportamiento incierto. | 3 | 4 | 12 | **ALTO** | Build reproducible + firma con Cosign | DevOps |
| **R-07** | V-07 | Respuesta lenta ante el incidente por falta de SBOM | El usuario permanece más tiempo afectado mientras se identifica la librería causante. | 4 | 3 | 12 | **ALTO** | SBOM (CycloneDX) por cada compilación + runbook | SRE |

***Conclusión:*** El mayor riesgo del caso (R-01 y R-02, nivel CRÍTICO) se origina en la falta de control de versiones sobre las librerías de terceros y en la ausencia de escaneo de vulnerabilidades (SCA/SAST) dentro del pipeline. Priorizar el fijado de versiones, la incorporación de SCA/SAST y un mecanismo de rollback automático reduce de forma directa la probabilidad de que la aplicación colapse al llegar al usuario final.